

Web 应用安全 — 问答问题集 (Q&A)

Web 应用安全 — 问答问题集 (Q&A)

配套文档: web-security.md 难度分层: 事实型 | 理解型 | 应用型
应用型**配套文档**: `web-security.md`
难度分层: 事实型 | 理解型 | 应用型
配套文档: web-security.md 难度分层: 事实型 | 理解型 | 应用型
应用型**配套文档**: `web-security.md`
难度分层: 事实型 | 理解型 | 应用型

事实型问题事实型问题

- Q1: OWASP Top 10 是什么?
Q2: Cookie 安全的一些关键属性是什么?
Q3: 密码哈希函数使用哪些算法? cost factor 建议多少?
Q4: CSP 脚本策略使用哪些算法? script-src self 表示什么?
Q5: JWT 为什么推荐使用非对称算法 (如 RS256) 而非对称算法 (如 HS256)?

理解型问题理解型问题

- Q6: 为什么输出编码需要根据上下文 (HTML/JavaScript/CSS/URL) 不同而采用不同的编码方式?
Q7: 解释 JWT 中 it's (JWT ID) 字段的作用: 为什么需要它?
Q8: Strict-Transport-Security 头中的 max-age=63072000 (2年) 和 includeSubDomains 有什么安全意义?

应用型问题应用型问题

- Q9: 一个用户反馈个人信息泄露, 怀疑是 XSS 攻击, 请设计安全加固方案。
Q10: 检查请里里如何注册/登录/找回密码/什么高频率请里。
Q11: 公司需要上线一个文件上传功能, 允许用户上传简历 PDF。请设计安全方案。

自信度评级: 事实型 95%+ | 理解型 85%+ | 应用型 80%+ **自信度评级**: 事实型 95%+ | 理解型 85%+ | 应用型 80%+
自信度评级: 事实型 95%+ | 理解型 85%+ | 应用型 80%+ **自信度评级**: 事实型 95%+ | 理解型 85%+ | 应用型 80%+